

Krayin 复盘

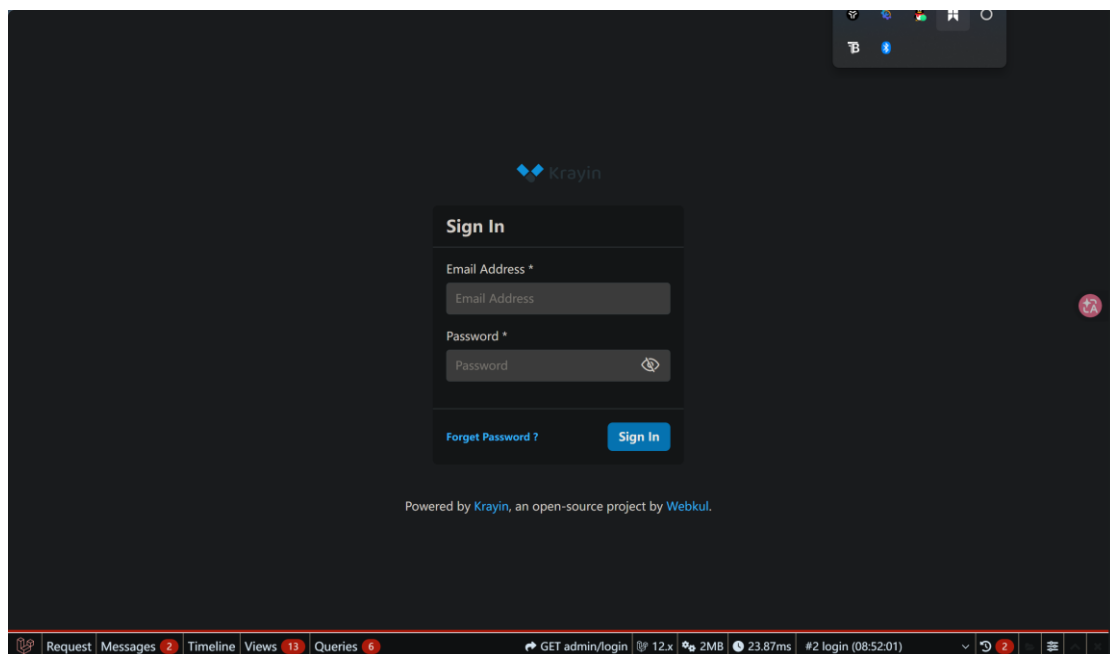
信息收集:

```
(kali㉿kali)-[~]
$ nmap 192.168.2.139
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-25 23:20 -0400
Nmap scan report for 192.168.2.139 (192.168.2.139)
Host is up (0.00040s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8080/tcp  open  http-proxy
MAC Address: 08:00:27:74:F7:A8 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.27 seconds
```

开放 22, 80, 8080 端口

Web:



有一个 cms, 搜索 github 仓库:

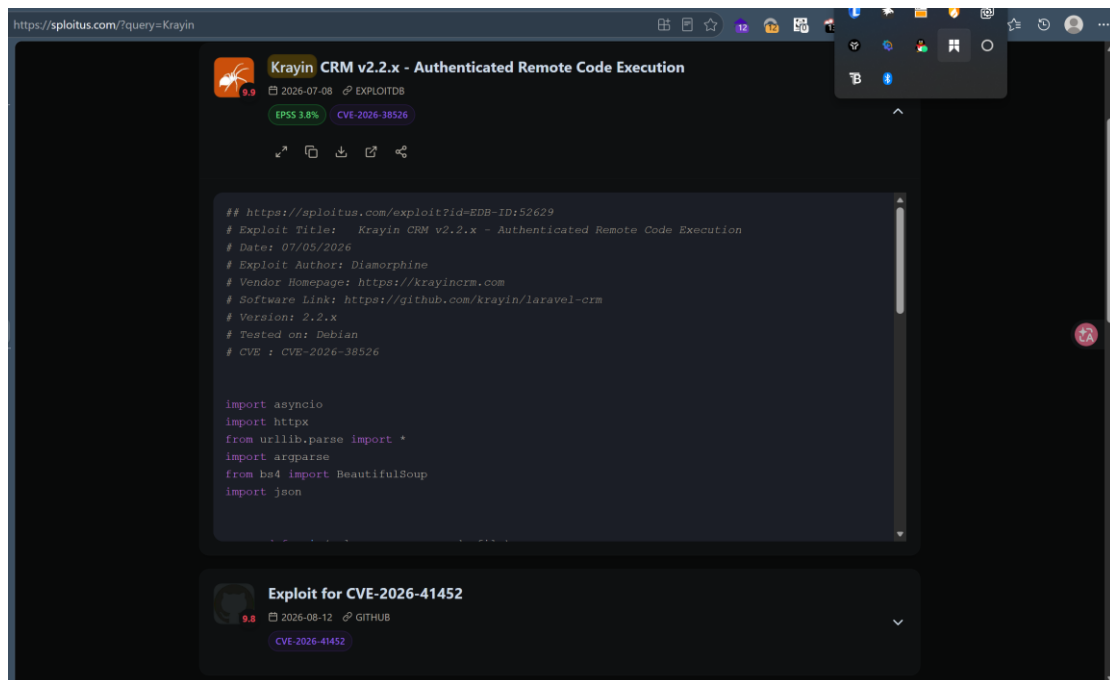
<https://github.com/krayin/laravel-crm>

```
http (s) ://example.com/admin/login

email:admin@example.com
password:admin123
```

用默认密码登录，然后把 cookie 复制下来。

找 cms 的 exp



将 exp 找到并修改，按照 exp 先建一个 shell.php 文件并上传

```
不安全 krayin.dsz:8080/storage/tinyMCE/9d6e6902b8e99a5318ae6537a5ba8070.php?cmd=id

uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

测试成功，进行反弹 shell

提权;

系统中有两个用户 krayin tonglinggejim0

运行 linpeas.sh (这里我遇到了一个报错

```
linpeas.sh: line 100: syntax error near unexpected token `'$in\r'  
'inpeas.sh: line 100: `  case "$opt" in
```

这里问 AI 然后改了一下就脚本好了)

发现有一个 **MySQL 服务**

- MySQL (MariaDB) 运行在 localhost:3306
- 用户名: krayin, 密码: root123

用这个来登录 krayin

拿到 krayin, 测试 sudo -l 没有权限, 翻翻找找没有东西了, 就用先前得到的密码组成字典爆破密码

爆破 root, tonglinggejim0。

最后得到 root 密码是 root123 tonglinggejim0 密码是 web 密码 admin123

得到 root 的 shell

Flag;flag{root-ac0abf8a8a25305c77f1ff1130ee82ab}

flag{user-5fd188d185e87bdc34fc0c1389d35409}